

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 — Dependency Scanner · Generated: 2026-06-25 · SHA: `61ed8c3`

Summary

Metric	Count
Dependencies scanned	22
Vulnerable dependencies	6
CRITICAL CVEs	6
HIGH CVEs	4
MEDIUM CVEs	4
LOW CVEs	1
Outdated dependencies	7
License violations	1
Supply-chain flags	2

CRITICAL — Log4Shell (CVE-2021-44228, CVSS 10.0). `log4j-core:2.14.1` and `log4j-api:2.14.1` are directly declared in `pom.xml` and actively imported by `DiscountCalculator.java`. Log4Shell allows unauthenticated remote code execution via JNDI injection in any logged string — the highest-severity known Java CVE. A second CRITICAL CVE-2021-45046 (CVSS 9.0) bypasses the original fix. Upgrade both artifacts to **2.17.2** immediately.

CRITICAL — Typosquatted dependency detected. `com.fastxml.jackson.core:jackson-databind:2.9.8` uses a misspelled groupId (missing "er") to impersonate the legitimate `com.fasterxml.jackson.core`. This coordinate is unresolvable on Maven Central — but if a compromised internal mirror were reachable, arbitrary malicious code would enter the compile classpath. Remove this entry immediately.

CRITICAL — Unsafe deserialization (jackson-databind 2.9.8). Four independent CRITICAL gadget-chain RCE CVEs (CVSS 9.8 each) plus 5 additional HIGH/MEDIUM CVEs affect this version. Over 900 days of publicly exploitable deserialization vulnerabilities have accumulated. Upgrade to **2.13.4.2** or higher.

HIGH — Untrusted HTTP repository. `pom.xml` declares repository `internal-untrusted-mirror` served over plain HTTP (`http://insecure-mirror.example.net/maven2`). Maven over HTTP allows man-in-the-middle substitution of any artifact with a malicious JAR. Remove or replace with HTTPS immediately.

CVE Findings

Dependency	Coordinate	CVE	Severity	CVSS	Fix Version
log4j-core	org.apache.logging.log4j:log4j-core:2.14.1	CVE-2021-44228	CRITICAL	10.0	2.17.2
log4j-core	org.apache.logging.log4j:log4j-core:2.14.1	CVE-2021-45046	CRITICAL	9.0	2.17.2
log4j-core	org.apache.logging.log4j:log4j-core:2.14.1	CVE-2021-44832	MEDIUM	6.6	2.17.2
log4j-api	org.apache.logging.log4j:log4j-api:2.14.1	CVE-2021-44228	CRITICAL	10.0	2.17.2
log4j-api	org.apache.logging.log4j:log4j-api:2.14.1	CVE-2021-45046	CRITICAL	9.0	2.17.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2019-16943	CRITICAL	9.8	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2019-14892	CRITICAL	9.8	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2019-14893	CRITICAL	9.8	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2019-14379	CRITICAL	9.8	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2021-20190	HIGH	8.1	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2020-36518	HIGH	7.5	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2022-42003	HIGH	7.5	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2022-42004	HIGH	7.5	2.13.4.2
jackson-databind	com.fasterxml.jackson.core:jackson-databind:2.9.8	CVE-2019-12384	MEDIUM	5.9	2.13.4.2
guava	com.google.guava:guava:24.1.1-jre	CVE-2022-25647	HIGH	7.7	30.0-jre
guava	com.google.guava:guava:24.1.1-jre	CVE-2018-10237	MEDIUM	5.9	24.1.1-jre
guava	com.google.guava:guava:24.1.1-jre	CVE-2020-8908	LOW	3.3	32.0.0-jre
commons-io	commons-io:commons-io:2.4	CVE-2021-29425	MEDIUM	4.8	2.7
mysql-connector-java	mysql:mysql-connector-java:8.0.30	CVE-2023-21971	MEDIUM	5.3	8.0.33

Outdated Dependencies

Dependency	Current	Safe Fix	Latest	Update Type
org.apache.logging.log4j:log4j-core	2.14.1	2.17.2	3.0.0-beta3	major

org.apache.logging.log4j:log4j-api	2.14.1	2.17.2	3.0.0-beta2	major
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.13.4.2	2.22.0	minor
com.google.guava:guava	24.1.1-jre	30.0-jre	33.6.0-jre	major
commons-io:commons-io	2.4	2.7	2.22.0	minor
org.apache.commons:commons-lang3	3.4	3.20.0	3.20.0	minor
mysql:mysql-connector-java	8.0.30	8.0.33	8.0.33	patch

License Violations

Dependency	License	Status	Action Required
mysql:mysql-connector-java:8.0.30	GPL-2.0 (with FOSS exception)	VIOLATION	Review GPL-2.0 compatibility with project license policy. Consider migrating to MariaDB Connector/J (LGPL) or MySQL Connector/J 9.x commercial.

Supply-Chain Flags

Flag Type	Coordinate / Resource	Detail
TYPOSQUATTED	com.fastxml.jackson.core:jackson-databind:2.9.8	Missing "er" in groupId — impersonates com.fasterxml.jackson.core. Unresolvable on Maven Central. Remove immediately.
UNTRUSTED_REPOSITORY	http://insecure-mirror.example.net/maven2	Plain HTTP mirror declared in pom.xml. Enables MITM artifact injection. Upgrade to HTTPS or remove.